

Audit Event Definition:

Define what actions must generate an audit log entry.

1. security-sensitive (authentication, permissions, access failures),
2. privacy-sensitive (data access, exports, report generation), or
3. governance actions (admin moderation, backups, configuration).

Audit Event Naming Conventions

- Event names use snake_case
- Outcomes are encoded in the event name or tags:
 - _success, _failure, _blocked
- Examples: login_success, login_failure, report_generation_blocked_k_threshold

Audit Event List

Each audit event records:

- Event type
- Timestamp
- Actor (account ID and role, when applicable)
- Target entity (e.g., form, report, user, cohort)
- Outcome (success/failure)
- Limited contextual metadata (e.g., reason code, IP address, user agent)

Authentication & Account Events

Event Name	Actor	Description
login_success	Any Role: User/ Admin/ Provider/ Researcher	Account successfully authenticates
login_failure	Any Role	Invalid credentials submitted
2fa_success	Any Role	Correct 2FA code verified
2fa_failure	Any Role	Incorrect 2FA code submitted
access_denied	Any Role	Actor attempts action without permission
logout	Any Role	User logs out of the system
Password_changed	Any Role	Password successfully updated
Password_reset_requested	Any Role	Password reset initiated

User & Health Data Events

Event Name	Actor	Description
form_submitted	User	User submits a completed health form
form_submission_failed	User	Form submission failed validation
health_goal_created	User	New health goal created
health_goal_updated	User	User updates personal health goal
health_goal_completed	User	Goal marked completed
personal_report_generated	User	User generates a personal report

Researcher Events

Event Name	Actor	Description
cohort_created	Researcher	Researcher defines a new cohort
cohort_updated	Researcher	Cohort definition modified
agg_report_generated	Researcher	System generates aggregated anonymous report
csv_export	Researcher	System generates and delivers CSV export
privacy_threshold_blocked	System	Report blocked due to cohort < k
form_templated_created	System	Researcher created new form template
form_template_updated	System	Researcher form template updated
researcher_db_updated	Researcher	Researcher updates controlled data
researcher_db_update_failed	Researcher	Update rejected or denied

Provider Events

Event Name	Actor	Description
patient_record_accessed	Provider	Provider accesses participant data
provider_viewed_report	Provider	Provider views report
feedback_created	Provider	Provider submits feedback

Admin & Governance Events

Event Name	Actor	Description
audit_log_viewed	Admin	Admin views audit logs
audit_log_exported	Admin	Admin logs exported
report_deleted	Admin	Admin deletes problematic report
form_approved	Admin	Form templated approved
form_rejected	Admin	Form templated rejected
backup_created	System	Database backup completed
backup_restored	System	Database restored
config_changed	System	Privacy or system settings updated

Audit Log Schema Design

Field	Description
id	Unique audit log entry identifier
event	Machine-readable audit event name
user_type	Actor role (User, Researcher, Provider, Admin, System)
user_id	Actor account ID
auditable_type	Type of affected resource
auditable_id	Identifier of affected resource
old_values	Non-sensitive prior state (IDs only)
new_values	Non-sensitive updated state (IDs only)
tags	Metadata such as outcome or category
url	Request URL (if applicable)
ip_address	Source IP address
user_agent	Client user agent

Auditable Target Strategy

For audit events that are not naturally associated with a specific domain object (such as authentication and logout events), the system attaches audit records to the authenticated account entity. This ensures that all audit entries are consistently linked to a concrete auditable target while avoiding the need for a separate system-wide audit anchor.

Under this strategy, authentication-related events (e.g., login success, login failure, logout) use the user account model as the auditable entity. This approach simplifies audit queries, maintains consistency with the existing auditing framework, and provides a clear trace of account-level activity without exposing sensitive data.

Implementation Mapping

- Event name → event
- Actor identity/role → user_id, user_type
- Resource affected → auditable_type, auditable_id
- Outcome / category → encoded in event name or tags
- Additional safe context → tags or structured JSON in new_values

Audit Logging Rules

- Audit logs are append-only and immutable
- Logs must never store:
 - Raw health values
 - Full form responses
 - Free-text provider notes
 - Direct identifiers (name, email, DOB, address)
- Only IDs, event codes, and minimal metadata may be recorded
- Audit logging failures must not block user actions but must be detectable by administrators

Retention and Access

- Audit logs are retained for 2 years
- Only administrators may view or export audit logs
- Export actions are themselves audited
- Logs are securely deleted after retention expiry in accordance with privacy best practices